

Лекция 7

Политики и модели разграничения доступа в компьютерных системах

Учебные вопросы:

1. Политика и модели безопасности в компьютерных системах
2. Субъектно – объектные модели разграничения доступа
3. Политика и модели дискреционного доступа
4. Политика и модели мандатного доступа
5. Политика и модели тематического разграничения доступа
6. Политика ролевой модели разграничения доступа

Дополнительный материал:



1

Политика и модели безопасности в компьютерных системах



— Под политикой безопасности понимается совокупность норм и правил, регламентирующих процесс обработки информации, выполнение которых обеспечивает защиту от определенного множества угроз и составляет необходимое условие безопасности системы.

Формальное выражение политики безопасности называют *моделью безопасности*.

**Основная цель создания
политики безопасности** — это
определение условий, которым должно
подчиняться поведение системы,
выработка критерия безопасности и
проведение формального
доказательства соответствия системы
этому критерию при соблюдении
установленных правил и ограничений.



Модели безопасности обеспечивают системотехнический подход, включающий решение следующих задач:

- выбор и обоснование базовых принципов архитектуры защищенных систем, определяющих механизмы реализации средств и методов защиты информации;
- подтверждение свойства защищенности разрабатываемых систем путем формального доказательства соблюдения политики безопасности;
- составление формальной спецификации политики безопасности как важнейшей составной части организационного и документационного обеспечения разрабатываемых защищенных систем.



Производители защищенных информационных систем используют модели безопасности в следующих случаях:

- при составлении формальной спецификации политики безопасности разрабатываемой системы;
- при выборе и обосновании базовых принципов архитектуры защищенной системы, определяющих механизмы реализации средств защиты;
- в процессе анализа безопасности системы, при этом модель используется в качестве эталонной модели;
- при подтверждении свойств разрабатываемой системы путем формального доказательства соблюдения политики безопасности.

2

Субъектно – объектные модели разграничения доступа



Разграничение доступа к информации — разделение информации, циркулирующей в информационной системе, на части, элементы, компоненты, объекты и т. д. и организация системы работы с информацией, предполагающей доступ пользователей к той части (к тем компонентам) информации, которая им необходима для выполнения функциональных обязанностей.

Модели безопасности основаны на «»»» следующих базовых представлениях:

1



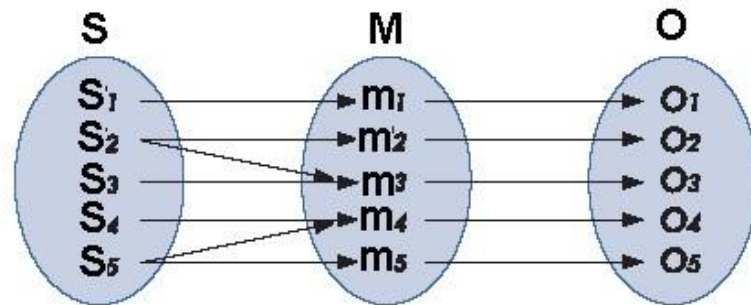
В системе действует дискретное время.

2



В каждый фиксированный момент времени система представляет собой конечное множество элементов, разделяемых на два подмножества:

- подмножество субъектов доступа S ;
- подмножество объектов доступа O .



Модель защиты информации по действующей концепции:
 S – множество субъектов (угроз); M – множество защитных функций;
 O – множество объектов защиты

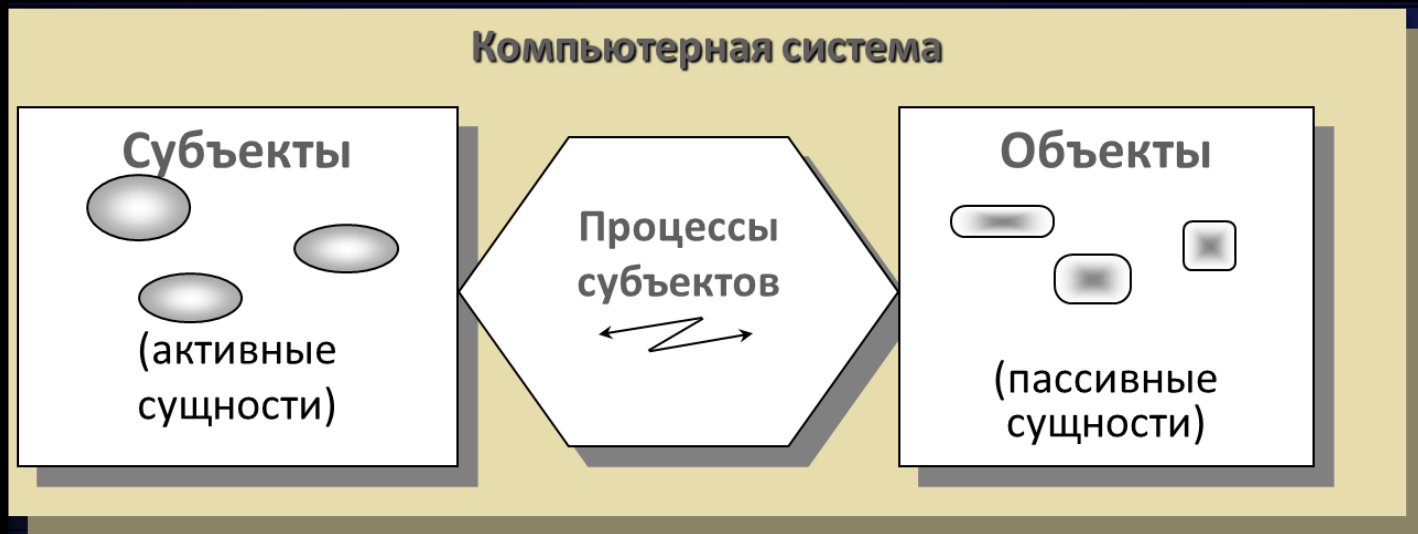
Модели безопасности основаны на «**« следующих базовых представлениях:**»»»»

- 3 Пользователи КС представлены одним или некоторой совокупностью субъектов доступа, действующих от имени конкретного пользователя.
- 4 Субъекты КС могут быть порождены из объектов только активной сущностью (другим субъектом).
- 5 Все взаимодействия в системе моделируются установлением отношений определенного типа между субъектами и объектами. Множество типов отношений определяется в виде набора операций, которые субъекты могут производить над объектами.

Модели безопасности основаны на « следующих базовых представлениях:

6

Все процессы безопасности в КС описываются доступами субъектов к объектам, вызывающими потоки информации.



Модели безопасности основаны на «**следующих базовых представлениях:**»

7

Политика безопасности задается в виде правил, в соответствии с которыми должны осуществляться все взаимодействия между субъектами и объектами. Взаимодействия, приводящие к нарушению этих правил, пресекаются средствами контроля доступа и не могут быть осуществлены

8

Все операции контролируются монитором безопасности и либо запрещаются, либо разрешаются в соответствии с правилами политики безопасности.

Политика безопасности задается в виде правил, в соответствии с которыми должны осуществляться все взаимодействия между субъектами и объектами. Взаимодействия, приводящие к нарушению этих правил, пресекаются средствами контроля доступа и не могут быть осуществлены

Все операции контролируются монитором безопасности и либо запрещаются, либо разрешаются в соответствии с правилами политики безопасности.



Модели безопасности основаны на « следующих базовых представлениях:

9

Совокупность множеств субъектов, объектов и отношений между ними (установившихся взаимодействий) определяет состояние системы. Каждое состояние системы является либо безопасным, либо небезопасным в соответствии с предложенным в модели критерием безопасности.

10

Основной элемент модели безопасности — это доказательство утверждения (теоремы) о том, что система, находящаяся в безопасном состоянии, не может перейти в небезопасное состояние при соблюдении всех установленных правил и ограничений.



— Под **субъектом доступа** понимается активная сущность КС, которая может изменять состояние системы через порождение процессов над объектами, в том числе, порождать новые объекты и инициализировать порождение новых субъектов.



— Под **объектом доступа** понимается пассивная сущность КС, процессы над которой могут в определенных случаях быть источником порождения новых субъектов.

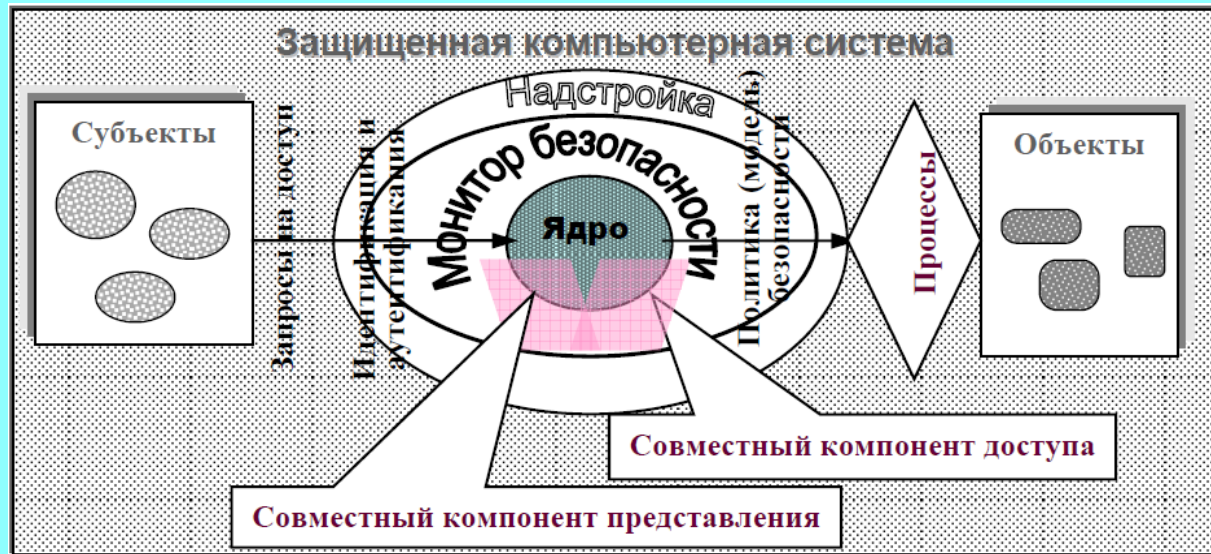


— Под пользователем КС понимается лицо, внешний фактор, аутентифицируемый некоторой информацией, и управляющий одним или несколькими субъектами, воспринимающий объекты и получающий информацию о состоянии КС через субъекты, которыми он управляет.

Понятия субъектов доступа и пользователей не тождественны.

- **Утверждение 1:** В защищенной информационной системе в любой момент времени любой субъект и объект должны быть идентифицированы и аутентифицированы.
- **Утверждение 2.** В защищенной системе должна присутствовать активная компонента (субъект, процесс и т. д.) с соответствующим объектом-источником, которая осуществляет управление доступом и контроль доступа субъектов к объектам, — монитор или ядро безопасности.

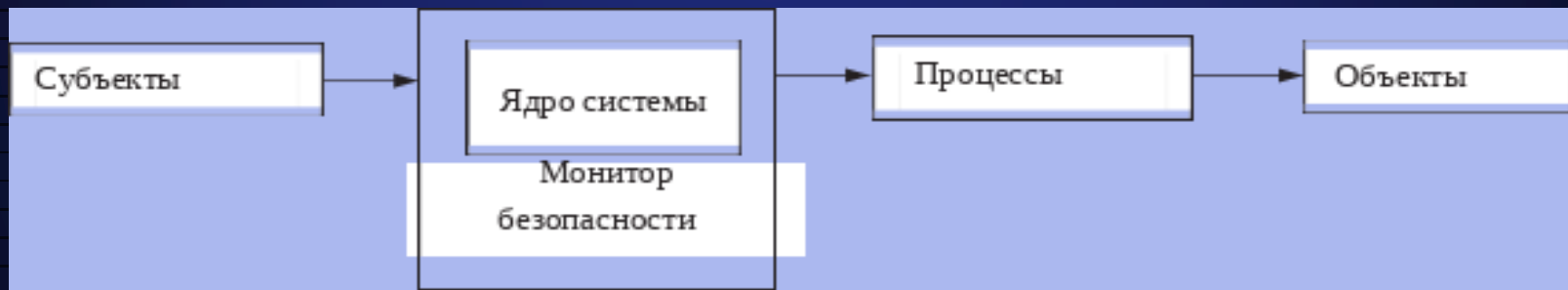
Монитор безопасности — механизм реализации политики безопасности в информационной системе, совокупность аппаратных, программных и специальных компонентов системы, реализующих функции защиты и обеспечения безопасности.



Монитор безопасности в защищенной системе является субъектом осуществления принятой политики безопасности, реализуя через алгоритмы своей работы соответствующие модели безопасности.



Незащищенная система



Защищенная система

Понятия субъектов доступа и пользователей не тождественны.

- **Утверждение 3.** Для реализации принятой политики безопасности, управления и контроля доступа субъектов к объектам необходима информация и объект, ее содержащий.
- Субъектом обеспечения политики безопасности выступает **монитор безопасности**. Его наличие в структуре системы соответственно является **необходимым** условием безопасности. Что касается условий **достаточности**, то они заключены в безопасности самого монитора безопасности.

3

Политика и модели дискреционного доступа



Политика дискреционного доступа (избирательного контроля) — первая проработанная модель безопасности. Она внедрена в большинстве защищенных информационных систем. Основные модели появились в 1960–1970-х годах: АДЕПТ-50 (конец 1960-х), модель Хартсона (начало 1970-х), Хариссона – Руззо – Ульмана (середина 1970-х) и Take-Grant (1976). Эти модели внесли значительный вклад в теорию безопасности и стали основой для создания защищенных систем.

Модели дискреционного доступа основаны на субъектно-объектной модели и расширяют её, включая множества взаимодействующих элементов. Безопасность определяется набором троек «пользователь (субъект) — поток (операция) — объект».

	O_1	O_2		O_k
S_1				
$M=S_2$	own R	W		
.....				
S_n				

строится прямоугольная матрица (таблица), строки которой соответствуют субъектам доступа, столбцы — объектам доступа, а в ячейках записываются разрешенные операции (права) субъекта над объектом.

В матрице используются следующие обозначения:
w — «писать», r — «читать», e — «исполнять».

Модель на основе матрицы доступа

объекты субъекты	file1	file2	dir1	file3	docA	docB	docC	docD	dir2	file4	pic1
adm	rwX	rwX	rwX	rwX	rwX	rwX	rwX	rwX	rwX	rwX	rwX
pgm1	---	---	---	r-X	---	---	---	---	rwX	rwX	---
pgm2	rwX	rwX	rwX	r-X	---	---	---	---	rwX	rwX	---
pgm3	rwX	rwX	rwX	---	---	---	---	---	---	---	---
op1	---	---	rwX	r-X	---	---	---	---	---	---	---
op2	---	---	rwX	r-X	---	---	---	---	---	---	---
op3	---	---	rwX	r-X	---	---	---	---	---	---	---
us1	--X	---	r--	---	rwX	rwX	---	r--	---	---	---
us2	---	---	r--	---	r--	r--	---	r--	---	---	---
us3	--X	---	r--	---	r--	r--	rwX	rwX	---	---	rwX

Матрица доступа представляет собой ассоциированный с монитором безопасности объект, содержащий информацию о политике разграничения доступа в конкретной системе. Структура матрицы, ее создание и изменение определяются конкретными моделями и конкретными программно-техническими решениями систем, в которых они реализуются.

Дискреционное разграничение доступа

	O_1 	O_2 	O_3 
 S_1	R W X	R X	R W X
 S_2	R X	R W	W X
 S_3	R	X	W

Принцип организации матрицы доступа в реальных системах определяет использование двух подходов — централизованного и распределенного.

При **распределенном подходе** матрица доступа не создается как отдельный объект. Вместо этого используются «списки доступа», привязанные к объектам системы, или «списки возможностей», привязанные к субъектам доступа. В первом случае каждый объект имеет связанный с ним список, аналогичный столбцу матрицы доступа. Во втором случае каждый субъект получает список разрешенных объектов при инициализации, что соответствует строке матрицы доступа.

При **централизованном подходе** матрица доступа создается как отдельный объект с особым порядком размещения и доступа. В реальных системах много объектов и субъектов доступа. Для упрощения матрицу делят на две группы: объекты с неограниченным доступом и объекты дискреционного доступа. В матрице указываются права пользователей только ко второй группе. Пример такого подхода — «биты доступа» в UNIX-системах.

Согласно принципу управления доступом выделяются *два* *подхода*:

принудительное управление доступом

- право создания и изменения матрицы доступа имеют только субъекты администратора системы, который при регистрации для работы в системе нового пользователя создает с соответствующим заполнением новую строку матрицы доступа, а при возникновении нового объекта, подлежащего избирательному доступу, образует новый столбец матрицы доступа. Подобный подход наиболее широко представлен в базах данных.

добровольное управление доступом

- основывается на принципе владения объектами. Владельцем объекта доступа называется пользователь, инициализировавший поток, в результате чего объект возник в системе, или определивший его иным образом. Права доступа к объекту определяют их владельцы.

4

Политика и модели мандатного доступа



Политика мандатного доступа является примером использования технологий, наработанных во в некомпьютерной сфере, в частности принципов организации секретного делопроизводства и документооборота, применяемых в государственных структурах большинства стран.

Основным положением политики мандатного доступа является назначение всем участникам процесса обработки защищаемой информации и документам, в которых она содержится, специальной метки, например секретно, сов. секретно и т. д., получившей название уровня безопасности.

Все уровни безопасности упорядочиваются с помощью установленного отношения доминирования, например, уровень сов. секретно считается более высоким, чем уровень секретно.

.....

Контроль доступа осуществляется в зависимости от уровней безопасности взаимодействующих сторон на основании двух правил

1.No read up (NRU) — нет чтения вверх: субъект имеет право читать только те документы, уровень безопасности которых не превышает его собственный уровень безопасности.

2.No write down (NWD) — нет записи вниз: субъект имеет право заносить информацию только в те документы, уровень безопасности которых не ниже его собственного уровня безопасности.

.....

—

—

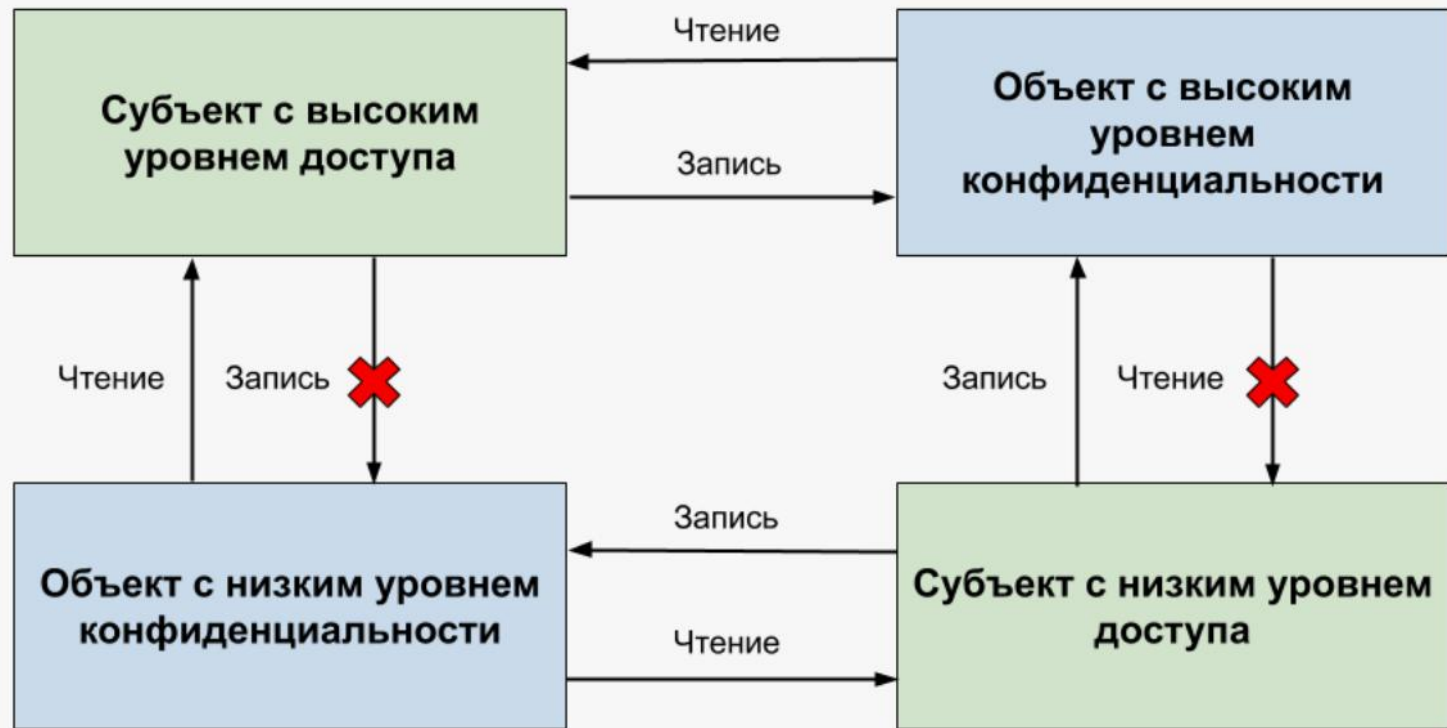




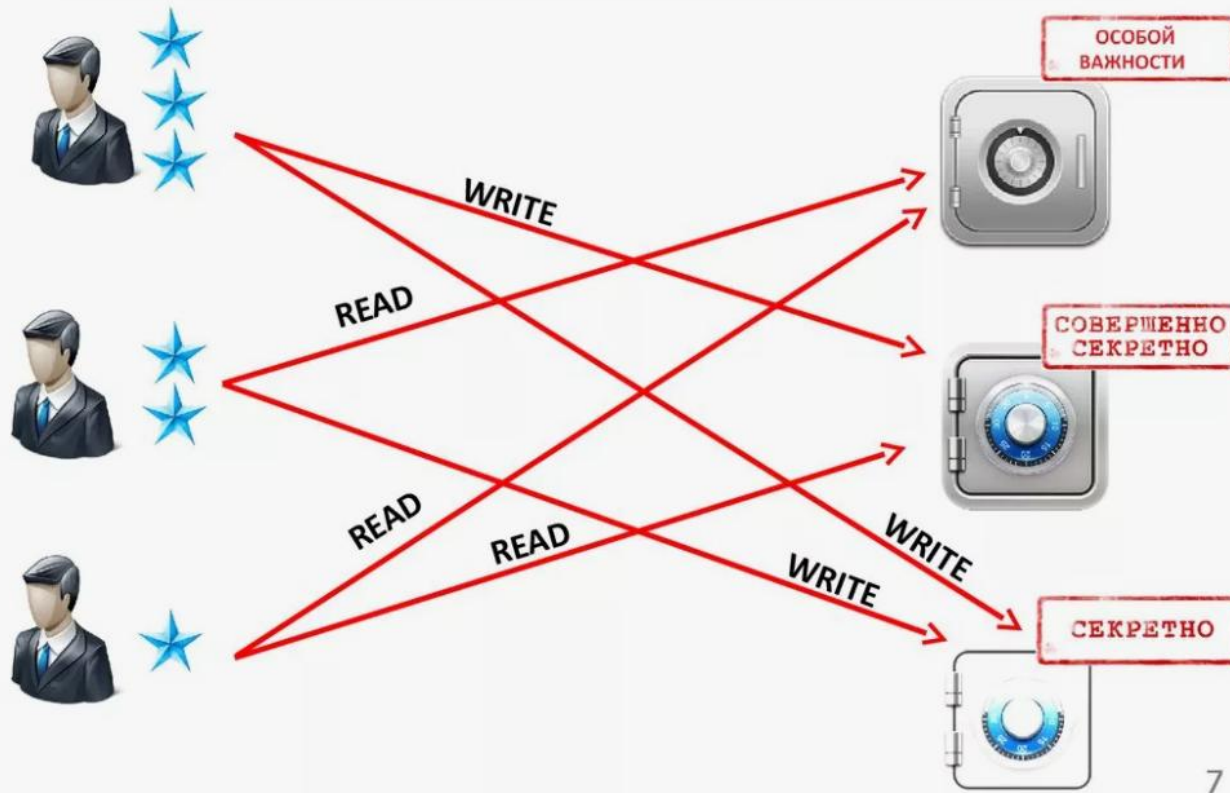
Первое правило обеспечивает защиту информации, обрабатываемой более доверенными (высокоуровневыми) лицами, от доступа со стороны менее доверенных (низкоуровневых).



Второе правило предотвращает утечку информации (сознательную или неосознанную) от высокоуровневых участников процесса обработки информации к низкоуровневым.



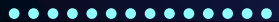
Мандатное модель доступа





Дискреционные модели управляют доступом через полномочия пользователей, тогда как мандатные модели используют уровни безопасности для определения взаимодействий между сущностями. В мандатных моделях все объекты определенного уровня безопасности доступны субъектам того же уровня (с учетом правил NRU и NWD). Однако такой подход часто приводит к избыточности прав.

Для устранения этого недостатка мандатный принцип дополняют дискреционным внутри классов безопасности, используя **матрицу доступа** для разграничения доступа к объектам одного уровня.



5

Политика и модели тематического разграничения доступа



Политика тематического разграничения доступа близка к политике мандатного доступа.

Общей основой является введение специальной процедуры классификации сущностей системы (субъектов и объектов доступа) по какому-либо критерию.

Для классификации информации и доступа к ней иногда используется тематическая структура предметной области, а не конфиденциальность данных и доверие, как в мандатных моделях. Для отражения тематического принципа в государственных организациях применяются MLS-решетки, которые представляют собой произведение линейной решетки уровней безопасности и решетки подмножеств категорий (тематик).



Необходимость построения специальных моделей тематического доступа обусловлена частичным порядком на классификационном множестве в информационных системах, задаваемым корневыми деревьями (иерархические и фасетные рубрикаторы), в отличие от линейного порядка в мандатных моделях.



Необходимость построения специальных моделей тематического доступа обусловлена частичным порядком на классификационном множестве в информационных системах, задаваемым корневыми деревьями (иерархические и фасетные рубрикаторы), в отличие от линейного порядка в мандатных моделях.



Важным аспектом разграничения доступа к бумажным ресурсам является их тематическая классификация по организационно-технологическим процессам и профилям деятельности. Доступ сотрудников к документам в библиотеках, архивах и хранилищах организуется с помощью тематических классификаторов. Документы индексируются по рубрикам классификатора, а сотрудники получают права доступа в соответствии со своими обязанностями. Этот подход, в сочетании с дискреционным и мандатным доступом, обеспечивает гибкую настройку системы контроля и управления доступом.

6

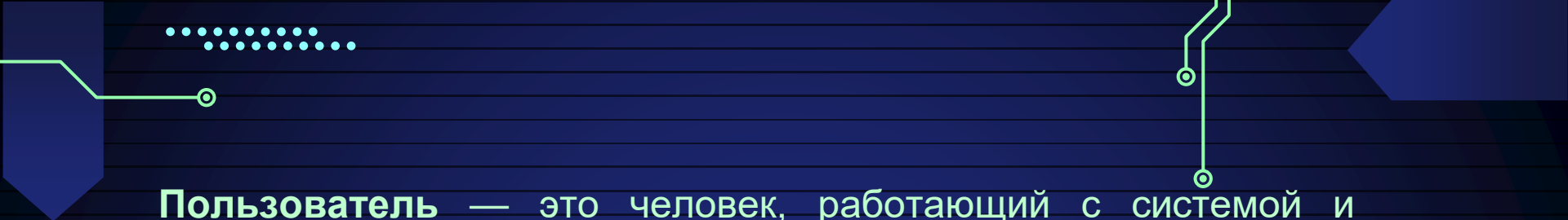
Политика ролевой модели разграничения доступа



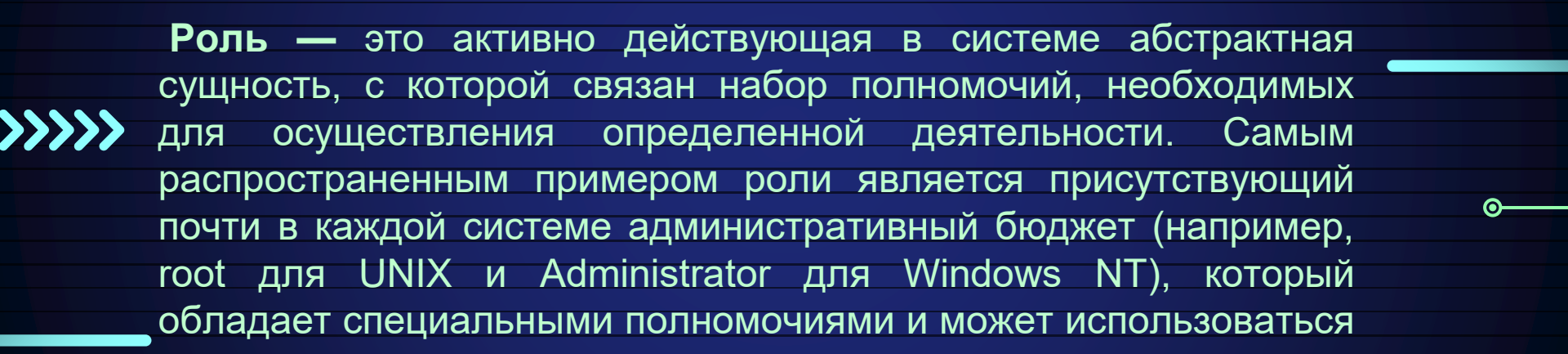
Ролевая модель безопасности

— это усовершенствованная модель Харрисона–Руззо–Ульмана. Она сочетает гибкость управления доступом дискреционных моделей с жесткостью мандатных. Управление доступом осуществляется через матрицу прав для ролей и правила их назначения пользователям. В этой модели понятие «субъект» заменено на «пользователь» и «роль».





Пользователь — это человек, работающий с системой и выполняющий определенные служебные обязанности.



Роль — это активно действующая в системе абстрактная сущность, с которой связан набор полномочий, необходимых для осуществления определенной деятельности. Самым распространенным примером роли является присутствующий почти в каждой системе административный бюджет (например, root для UNIX и Administrator для Windows NT), который обладает специальными полномочиями и может использоваться несколькими пользователями.

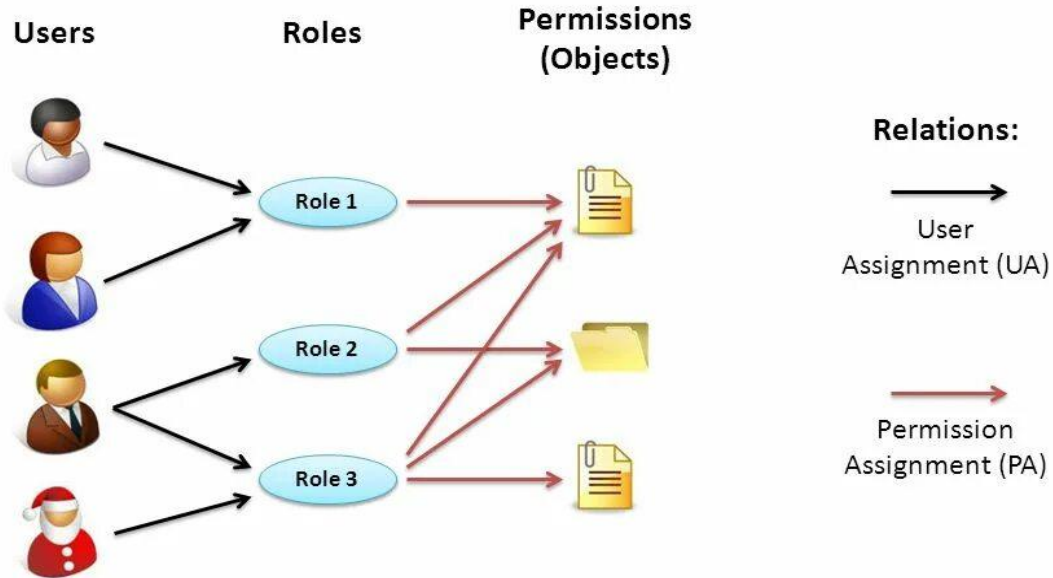


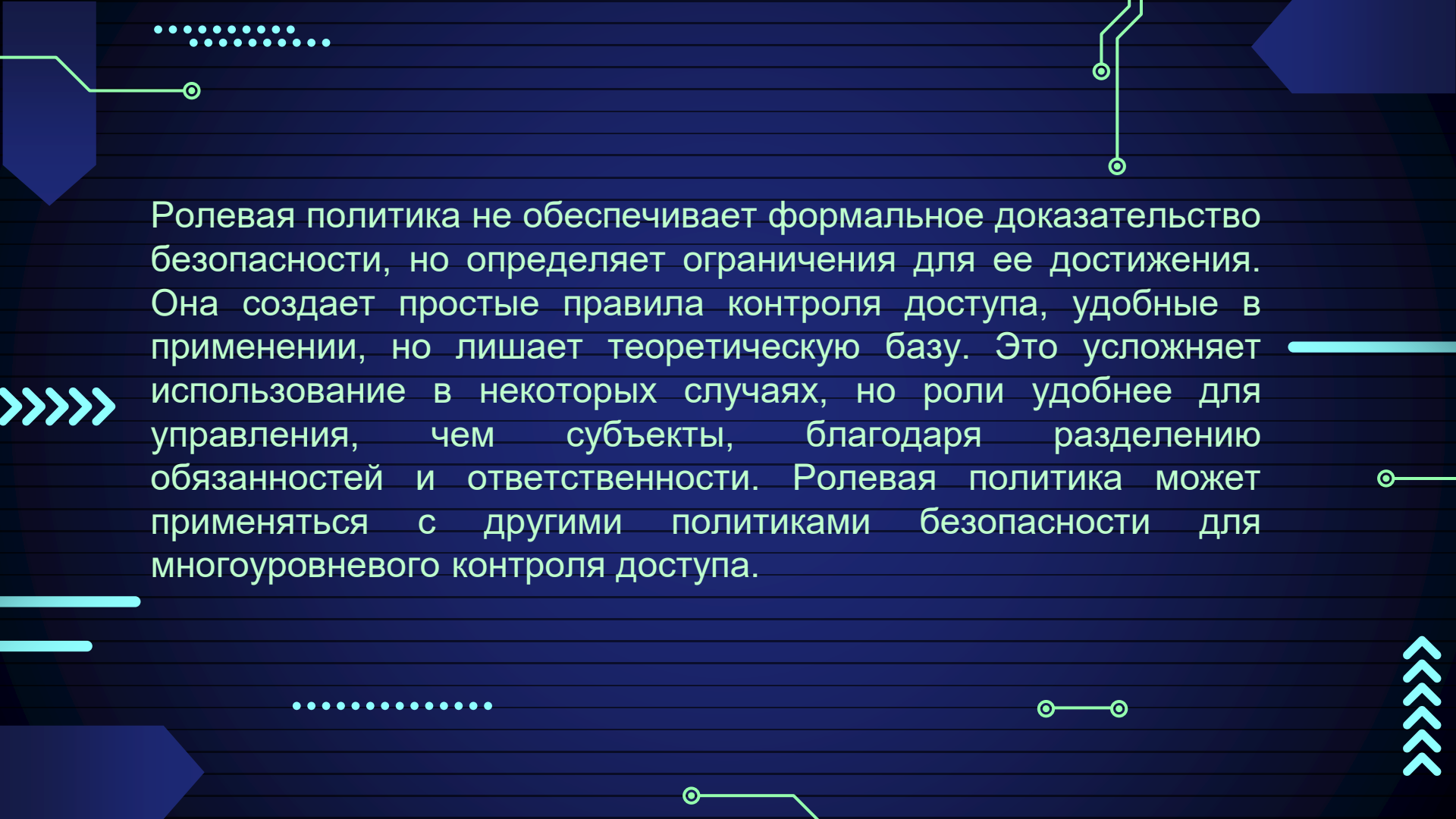
При использовании ролевой политики управление доступом осуществляется в две стадии:

во-первых, для каждой роли указывается набор полномочий, представляющий набор прав доступа к объектам

во-вторых — каждому пользователю назначается список доступных ему ролей. Полномочия назначаются ролям в соответствии с принципом наименьших привилегий, из которого следует, что каждый пользователь должен обладать только минимально необходимым для выполнения своей работы набором полномочий.

Basic RBAC Illustrated





Ролевая политика не обеспечивает формальное доказательство безопасности, но определяет ограничения для ее достижения. Она создает простые правила контроля доступа, удобные в применении, но лишает теоретическую базу. Это усложняет использование в некоторых случаях, но роли удобнее для управления, чем субъекты, благодаря разделению обязанностей и ответственности. Ролевая политика может применяться с другими политиками безопасности для многоуровневого контроля доступа.